

Penetration Testing Report — Mediroza General Hospital

Week 4 | Batch B083 | Black-Box Web Application Assessment

Client	Mediroza General Hospital
Target	https://medirozahospital.com
Assessment	Black-box penetration test
Duration	5 days
Environment	Authorized educational / controlled environment

1. Executive Summary

This report documents the Week 4 black-box penetration-testing exercise for Mediroza General Hospital. The engagement was conducted in a controlled training environment with written authorization and a five-day scope. The assessment focused on reconnaissance, exposed entry points, authentication behavior, restricted-area access, confidential patient-report access, encrypted-file analysis, and critical data exposure involving staff and shareholder information. The project brief defines four milestones: initial access (M1), data extraction (M2), critical data exposure (M3), and professional reporting (M4).

2. Scope and Rules of Engagement

- Target: https://medirozahospital.com
- Client: Mediroza General Hospital
- Assessment type: Black-box penetration test
- Duration: 5 days
- Scope: Target domain only
- Excluded activities: social engineering and denial-of-service testing
- Authorization: written permission granted by the training project

3. Methodology

1. Reconnaissance and enumeration
2. Authentication and restricted-area testing
3. HTTP behavior inspection
4. File and database analysis
5. Evidence collection and reporting

4. Assessment Milestones

Milestone	Objective
M1 — Initial Access	Find three confidential patient PDF laboratory reports and provide proof of access.
M2 — Data Extraction	Analyze and recover the contents of all three encrypted files with proof of successful access.
M3 — Critical Data Exposure	Identify the exposure leading to staff salary and shareholder information and document the evidence.
M4 — Penetration Test Report	Produce a professional report covering findings, risk, evidence, and remediation.

5. Findings and Proof of Exploitation

ID	Finding	Risk	Summary
F-01	Sensitive patient-report access	Critical	During the authorized lab exercise, restricted patient-report material was accessed. The project objective explicitly required this.
F-02	Exposed database backup / sensitive records	Critical	An exposed SQL backup was identified during the assessment. The backup contained database structures for sensitive data.
F-03	Exposed application resources	High	Reconnaissance identified application resources and entry points, including authentication-related pages and legacy endpoints.
F-04	Authentication / access-control weakness	High	The assessment investigated patient-portal authentication and restricted-area behavior. Evidence collected during the exercise.

6. Evidence Handling

Evidence should be stored securely. Do not publish patient identifiers, medical results, passwords, database dumps, or other sensitive records. Public screenshots should be redacted.

7. Risk Rating

Critical: exposure of highly sensitive patient or organizational information. High: weaknesses materially increasing unauthorized-access risk.

8. Recommendations and Remediation

- Remove database backups, logs, configuration files, and legacy application files from publicly accessible web directories.
- Store backups outside the web root and protect them with strong access controls and encryption.
- Implement server-side authorization checks for every patient record and sensitive resource; do not rely on client-side restrictions.
- Require strong authentication and secure session management for patient and administrative portals.
- Apply least-privilege access to staff, shareholder, and patient information.
- Review web-server directory exposure and disable unnecessary directory listing.
- Remove obsolete application components and restrict access to administrative or legacy paths.
- Log and monitor access to sensitive records and investigate unusual access patterns.
- Conduct periodic authenticated and unauthenticated security testing after remediation.
- Redact patient-identifying and medical information from training evidence and public repositories.

9. Conclusion

The assessment demonstrated how exposed resources, access-control weaknesses, and improperly protected data stores can combine to create significant confidentiality risks.

10. Ethical and Legal Notice

This report is for the authorized NetworkWalks training exercise only. The project brief states that the target was authorized and that the techniques must not be used without explicit permission.